



Advanced Threat Analysis

This document provides an overview of advanced threat analysis, focusing on core concepts such as threat modeling using STRIDE, the MITRE ATT&CK framework, and advanced attack vectors like APTs, supply chain attacks, and zero-day exploits. The objective is to equip readers with the knowledge and skills to proactively identify, analyze, and mitigate sophisticated threats.

Core Concepts

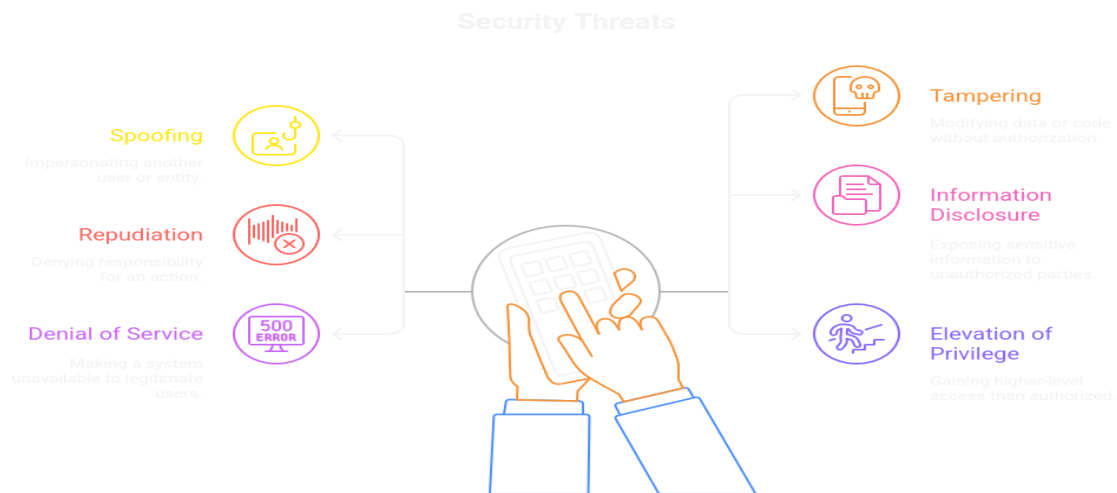
Threat Modeling

Threat modeling is a structured approach to identifying, quantifying, and addressing potential security threats in a system or application. It involves understanding the system's architecture, identifying assets, entry points, and trust boundaries, and then systematically analyzing potential threats. One of the most widely used methodologies for threat modeling is STRIDE.

STRIDE

STRIDE is an acronym that represents six categories of threats:

- **Spoofing:** Impersonating another user or entity.
- **Tampering:** Modifying data or code without authorization.
- **Repudiation:** Denying responsibility for an action.
- **Information Disclosure:** Exposing sensitive information to unauthorized parties.
- **Denial of Service (DoS):** Making a system or service unavailable to legitimate users.
- **Elevation of Privilege:** Gaining higher-level access than authorized.



Applying STRIDE

To apply STRIDE effectively, follow these steps:

1. **Identify Assets:** Determine what needs protection (e.g., user data, system configurations, intellectual property).
2. **Identify Entry Points:** Determine how attackers can interact with the system (e.g., user interfaces, APIs, network connections).
3. **Identify Trust Boundaries:** Determine where different levels of trust exist within the system (e.g., between different modules, between the application and the database).
4. **Analyze Threats:** For each asset, entry point, and trust boundary, consider each STRIDE category and identify potential threats.
5. **Prioritize Threats:** Assess the likelihood and impact of each threat to prioritize mitigation efforts.
6. **Mitigate Threats:** Implement security controls to reduce the likelihood or impact of the identified threats.

Example: Applying STRIDE to a Web Application

Consider a web application with user authentication. Let's apply STRIDE to identify potential threats:

- **Asset:** User credentials (usernames and passwords).
- **Entry Point:** Login form.
- **Trust Boundary:** Between the user's browser and the web server.

Now, let's analyze potential threats using STRIDE:



- **Spoofing:** An attacker could create a fake login page to steal user credentials (phishing).
- **Tampering:** An attacker could intercept and modify the login request to bypass authentication.
- **Repudiation:** A user could deny having performed an action, such as making a purchase.
- **Information Disclosure:** The web server could leak user credentials in error messages or logs.
- **Denial of Service:** An attacker could flood the login page with requests to make it unavailable.
- **Elevation of Privilege:** An attacker could exploit a vulnerability to gain administrative access.

By identifying these threats, developers can implement appropriate security controls, such as multi-factor authentication, input validation, encryption, and rate limiting, to mitigate the risks.

MITRE ATT&CK Framework

The MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) framework is a knowledge base of adversary tactics and techniques based on real-world observations. It provides a common language for describing adversary behaviors and can be used to understand, analyze, and defend against cyber attacks.

Tactics and Techniques

The ATT&CK framework organizes adversary behaviors into tactics and techniques:

- **Tactics:** Represent the high-level goals of an adversary during an attack (e.g., Initial Access, Execution, Persistence).
- **Techniques:** Represent the specific methods an adversary uses to achieve a tactic (e.g., T1566 - Phishing, T1059 - Command and Scripting Interpreter).

Each technique is associated with a description, examples of use, mitigation strategies, and detection methods.

Using the MITRE ATT&CK Framework

The ATT&CK framework can be used for various purposes, including:

- **Threat Intelligence:** Understanding adversary behaviors and identifying potential threats.
- **Detection and Analysis:** Mapping observed behaviors to ATT&CK techniques to understand the attacker's goals and methods.



- **Red Teaming:** Simulating adversary behaviors to test defenses.
- **Gap Analysis:** Identifying gaps in security controls and prioritizing improvements.

Example: Mapping a Phishing Attack

Consider a phishing attack where an attacker sends an email with a malicious attachment that, when opened, executes a PowerShell script to download and install malware. Using the MITRE ATT&CK framework, we can map this attack to the following tactics and techniques:

- **Tactic:** Initial Access (TA0001)
 - **Technique:** Phishing (T1566)
 - **Sub-technique:** Attachment (T1566.001)
- **Tactic:** Execution (TA0002)
 - **Technique:** Command and Scripting Interpreter (T1059)
 - **Sub-technique:** PowerShell (T1059.001)

By mapping the attack to ATT&CK techniques, security professionals can better understand the attacker's methods and implement appropriate detection and mitigation strategies, such as email filtering, endpoint detection and response (EDR), and user awareness training.

Advanced Attack Vectors

Advanced attack vectors are sophisticated methods used by adversaries to compromise systems and networks. These attacks often involve multiple stages, advanced techniques, and a high degree of stealth. Some common advanced attack vectors include:

- **Advanced Persistent Threats (APTs):** Long-term, targeted attacks carried out by sophisticated adversaries, often nation-states or organized crime groups.
- **Supply Chain Attacks:** Attacks that target third-party suppliers or vendors to gain access to their customers' systems.
- **Zero-Day Exploits:** Attacks that exploit previously unknown vulnerabilities in software or hardware.

Advanced Persistent Threats (APTs)

APTs are characterized by their persistence, sophistication, and targeted nature. APT actors often have specific goals, such as stealing intellectual property, disrupting critical infrastructure, or conducting espionage.

Supply Chain Attacks



Supply chain attacks target the weakest link in an organization's supply chain to gain access to its systems. These attacks can be difficult to detect and mitigate because they often involve compromising trusted third parties.

Zero-Day Exploits

Zero-day exploits are attacks that exploit vulnerabilities that are unknown to the vendor or the public. These attacks are particularly dangerous because there are no patches or workarounds available to protect against them.

Example: Analyzing the SolarWinds Attack

The SolarWinds attack was a supply chain attack that compromised the Orion network management software used by thousands of organizations worldwide. Attackers injected malicious code into the Orion software, which allowed them to gain access to the networks of SolarWinds' customers.

This attack can be analyzed using the MITRE ATT&CK framework to understand the tactics and techniques used by the attackers:

- **Tactic:** Initial Access (TA0001)
 - **Technique:** Supply Chain Compromise (T1195)
 - **Sub-technique:** Compromise Software Supply Chain (T1195.001)
- **Tactic:** Persistence (TA0003)
 - **Technique:** Implant System (T1199)
- **Tactic:** Command and Control (TA0011)
 - **Technique:** Application Layer Protocol (T1071)

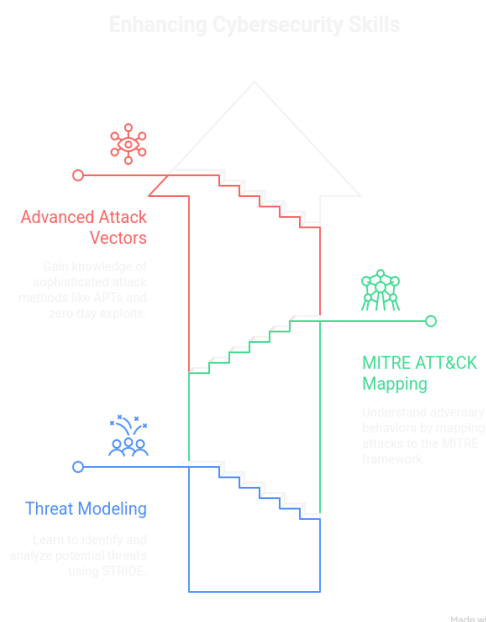
By understanding the tactics and techniques used in the SolarWinds attack, organizations can improve their defenses against similar attacks, such as implementing stricter vendor security requirements, monitoring network traffic for suspicious activity, and using threat intelligence to identify potential threats.

Key Objectives

The key objectives of advanced threat analysis are to:

- Build skills to model threats using methodologies like STRIDE.
- Map attacks to the MITRE ATT&CK framework to understand adversary behaviors.
- Understand sophisticated attack vectors, such as APTs, supply chain attacks, and zero-day exploits, for proactive defense.

By achieving these objectives, security professionals can proactively identify, analyze, and mitigate advanced threats, protecting their organizations from cyber attacks.



Learning MITRE ATT&CK

This document provides a practical guide to learning cybersecurity by exploring key concepts and tools. It covers using the MITRE ATT&CK framework, analyzing real-world breaches like the SolarWinds attack, creating threat models, and studying zero-day exploits. This approach combines theoretical knowledge with hands-on experience to build a solid foundation in cybersecurity.

Exploring MITRE ATT&CK

The MITRE ATT&CK framework is a comprehensive knowledge base of adversary tactics and techniques based on real-world observations. It serves as a foundation for the development of specific threat models and methodologies in the private sector, government, and cybersecurity product and service communities.



Accessing MITRE ATT&CK

1. **Visit attack.mitre.org:** This is the official website for the MITRE ATT&CK framework. It provides detailed information on various tactics, techniques, and procedures (TTPs) used by adversaries.
2. **Navigate the Framework:** The website organizes the framework into different matrices, including:
 - ****Enterprise ATT&CK:**** Focuses on tactics and techniques used against enterprise environments.
 - ****Mobile ATT&CK:**** Covers tactics and techniques targeting mobile devices.
 - ****ICS ATT&CK:**** Addresses tactics and techniques used against industrial control systems.

Using the ATT&CK Navigator

The ATT&CK Navigator is a web-based tool that allows you to visualize and annotate the ATT&CK framework. It helps in creating attack chains and understanding adversary behavior.

1. **Access the ATT&CK Navigator:** You can find the Navigator on the MITRE ATT&CK website or directly at a dedicated URL (search for "MITRE ATT&CK Navigator").
2. **Create a New Layer:**
 - Open the Navigator and create a new layer.
 - You can start with a blank layer or import an existing one.
3. **Select Tactics and Techniques:**
 - Browse through the tactics and techniques in the matrix.
 - Select the techniques that are relevant to your area of interest or the threats you are analyzing.
4. **Annotate Techniques:**
 - You can annotate each technique with additional information, such as:
 - ****Score:**** Assign a score to indicate the likelihood or impact of the technique.
 - ****Comment:**** Add notes about how the technique is used or how to defend against it.
 - ****Color:**** Use different colors to categorize techniques or highlight specific aspects.
5. **Visualize Attack Chains:**



- By selecting and annotating techniques, you can create a visual representation of an attack chain.
- This helps in understanding the sequence of actions an adversary might take and identifying potential points of intervention.

Example: Creating an Attack Chain

Let's say you want to visualize an attack chain for a ransomware attack:

1. **Initial Access:** The attacker gains initial access through "Phishing" (T1566).
2. **Execution:** The attacker executes malicious code using "User Execution" (T1204).
3. **Persistence:** The attacker establishes persistence using "Create or Modify System Process" (T1543).
4. **Privilege Escalation:** The attacker escalates privileges using "Exploitation for Privilege Escalation" (T1068).
5. **Defense Evasion:** The attacker evades defenses using "Impair Defenses" (T1562).
6. **Credential Access:** The attacker accesses credentials using "Credential Dumping" (T1003).
7. **Discovery:** The attacker performs discovery using "Network Service Scanning" (T1046).
8. **Lateral Movement:** The attacker moves laterally using "Remote Services" (T1021).
9. **Collection:** The attacker collects data using "Data from Local System" (T1005).
10. **Exfiltration:** The attacker exfiltrates data using "Exfiltration Over C2 Channel" (T1041).
11. **Impact:** The attacker encrypts data using "Data Encrypted for Impact" (T1486).



By visualizing this attack chain in the ATT&CK Navigator, you can see the steps involved and identify areas where you can implement security controls to prevent or detect the attack.

Analyzing the SolarWinds 2020 Breach

The SolarWinds 2020 breach was a sophisticated supply chain attack that affected numerous organizations. Analyzing this breach can provide valuable insights into the mechanics of such attacks and how to defend against them.

Understanding the Attack

1. **Supply Chain Attack:** The attackers compromised SolarWinds' Orion software build process. This allowed them to insert malicious code into legitimate software updates.
2. **Distribution:** When customers installed the updated Orion software, the malicious code was deployed within their networks.
3. **Lateral Movement and Data Exfiltration:** The attackers used the compromised systems to move laterally within the networks and exfiltrate sensitive data.



Resources for Analysis

1. **KrebsOnSecurity:** KrebsOnSecurity provides in-depth reporting and analysis of the SolarWinds breach. You can find articles and reports detailing the timeline, techniques, and impact of the attack.
2. **Mandiant:** Mandiant (now part of Google Cloud) conducted incident response and forensic analysis of the SolarWinds breach. Their reports provide technical details about the malware used and the attacker's tactics.

Key Takeaways

- **Supply Chain Risks:** The SolarWinds breach highlights the risks associated with supply chain vulnerabilities. Organizations need to assess the security practices of their vendors and implement controls to mitigate these risks.
- **Detection Challenges:** The attackers used sophisticated techniques to evade detection. This underscores the importance of advanced threat detection capabilities, such as behavioral analysis and anomaly detection.
- **Incident Response:** The breach demonstrates the need for robust incident response plans. Organizations should have procedures in place to quickly detect, contain, and recover from security incidents.

Creating a STRIDE-Based Threat Model

Threat modeling is a process of identifying and prioritizing potential threats to a system. STRIDE is a common threat modeling methodology that focuses on six categories of threats:

- **Spoofing:** Impersonating an identity.
- **Tampering:** Modifying data or code.
- **Repudiation:** Denying an action.
- **Information Disclosure:** Exposing sensitive information.
- **Denial of Service:** Making a system unavailable.
- **Elevation of Privilege:** Gaining unauthorized access.

Using OWASP Threat Dragon

OWASP Threat Dragon is a free, open-source threat modeling tool that supports the STRIDE methodology.

1. **Download and Install Threat Dragon:** You can download Threat Dragon from the OWASP website or GitHub.
2. **Create a New Diagram:**



- Open Threat Dragon and create a new diagram for your sample web application.
- Define the scope of the application and its key components.

3. Add Components:

- Add components to the diagram, such as:
- ****User:**** Represents the end-user of the application.
- ****Web Browser:**** Represents the user's web browser.
- ****Web Server:**** Represents the server hosting the application.
- ****Database:**** Represents the database storing application data.

4. Add Data Flows:

- Add data flows between the components to represent the flow of information.
- For example, a data flow from the "User" to the "Web Server" might represent a user submitting a form.

5. Identify Threats:

- For each component and data flow, identify potential threats using the STRIDE categories.
- For example, a threat to the "Web Server" might be "Denial of Service" (DoS) if an attacker floods the server with requests.

6. Analyze and Mitigate Threats:

- Analyze the identified threats and prioritize them based on their likelihood and impact.
- Develop mitigation strategies for each threat, such as:
- ****Input Validation:**** To prevent tampering.
- ****Authentication:**** To prevent spoofing.
- ****Encryption:**** To prevent information disclosure.

7. Document the Threat Model:

- Threat Dragon allows you to document the threat model, including the identified threats, their mitigations, and their status.
- This documentation can be used to track progress and ensure that all threats are addressed.



Studying Zero-Day Exploits

Zero-day exploits are vulnerabilities that are unknown to the vendor and for which no patch is available. Studying these exploits can help you understand the challenges of detecting and preventing attacks that exploit them.

Using Exploit-DB

Exploit-DB is a comprehensive archive of exploits and vulnerability information. It provides a valuable resource for learning about zero-day exploits and how they are used.

1. **Access Exploit-DB:** Visit exploit-db.com.
2. **Search for Zero-Day Exploits:**
 - Use the search function to find exploits that are classified as "zero-day."
 - You can also filter by software, operating system, or vulnerability type

Security Frameworks in Depth

This document provides an in-depth exploration of security frameworks, specifically the NIST Cybersecurity Framework (CSF) and ISO 27001. It delves into the core concepts of each framework, including their functions, controls, and application in real-world scenarios. The document also outlines practical steps for learning and applying these frameworks to design and evaluate cybersecurity programs tailored to organizational needs.

Core Concepts

NIST Cybersecurity Framework (CSF)

The NIST Cybersecurity Framework (CSF) is a voluntary framework primarily intended for organizations in the United States, but it is used globally. It provides a structured approach to managing and reducing cybersecurity risks. The CSF is built around five core functions: Identify, Protect, Detect, Respond, and Recover. These functions are not sequential but rather iterative and interconnected, forming a continuous cycle of improvement.

1. **Identify:** This function focuses on developing an organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities. Activities include:
 - ****Asset Inventory:**** Creating a comprehensive list of all hardware, software, and data assets.



-
- ****Business Environment:**** Understanding the organization's mission, objectives, and activities.
 - ****Governance:**** Establishing policies, procedures, and processes for managing cybersecurity risk.
 - ****Risk Assessment:**** Identifying and evaluating potential threats and vulnerabilities.
 - ****Risk Management Strategy:**** Developing a plan to address identified risks.
-
- ****Example:**** In a mock organization, the Identify function would involve cataloging all critical assets, such as servers, workstations, network devices, and sensitive data repositories. This would also include understanding the business processes that rely on these assets and the potential impact of a cybersecurity incident.
2. **Protect:** This function outlines the safeguards to ensure the delivery of critical infrastructure services. Activities include:
- ****Access Control:**** Implementing measures to restrict access to systems and data based on roles and permissions.
 - ****Awareness and Training:**** Providing cybersecurity training to employees to reduce the risk of human error.
 - ****Data Security:**** Implementing measures to protect data at rest and in transit, such as encryption and data loss prevention (DLP).
 - ****Information Protection Processes and Procedures:**** Establishing policies and procedures for handling sensitive information.
 - ****Maintenance:**** Regularly maintaining systems and software to address vulnerabilities.
 - ****Protective Technology:**** Deploying security technologies such as firewalls, intrusion detection systems (IDS), and antivirus software
-
- ****Example:**** Implementing multi-factor authentication (MFA) for all user accounts, encrypting sensitive data stored on laptops, and providing regular cybersecurity awareness training to employees.
3. **Detect:** This function defines the activities to identify the occurrence of a cybersecurity event. Activities include:
- ****Anomalies and Events:**** Monitoring systems and networks for unusual activity.
 - ****Security Continuous Monitoring:**** Continuously monitoring security controls to ensure they are effective.
 - ****Detection Processes:**** Establishing procedures for detecting and analyzing security incidents
-
- ****Example:**** Implementing a Security Information and Event Management (SIEM) system to collect and analyze logs from various sources, setting up alerts for suspicious activity, and regularly reviewing security logs for potential incidents.



4. **Respond:** This function outlines the actions to take regarding a detected cybersecurity incident. Activities include:
 - ****Response Planning:**** Developing an incident response plan to guide actions during a security incident.
 - ****Analysis:**** Analyzing the incident to determine its scope, impact, and cause.
 - ****Mitigation:**** Taking steps to contain the incident and prevent further damage.
 - ****Improvements:**** Identifying and implementing improvements to the incident response process based on lessons learned.
 - ****Communications:**** Communicating with internal and external stakeholders about the incident.
 - ****Example:**** Following a defined incident response plan to contain a malware outbreak, isolating affected systems, and notifying relevant stakeholders.
5. **Recover:** This function identifies activities to restore systems and capabilities impaired due to a cybersecurity incident. Activities include:
 - ****Recovery Planning:**** Developing a recovery plan to restore systems and data after an incident.
 - ****Improvements:**** Identifying and implementing improvements to the recovery process based on lessons learned.
 - ****Communications:**** Communicating with internal and external stakeholders about the recovery process.
 - ****Example:**** Restoring systems from backups after a ransomware attack, verifying the integrity of the restored data, and communicating with customers about the service disruption.

ISO 27001 Controls

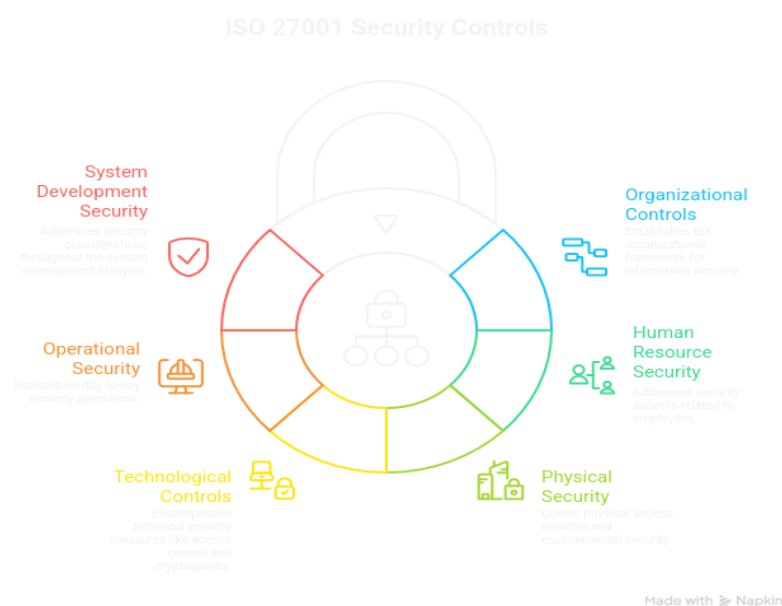
ISO 27001 is an international standard that specifies the requirements for establishing, implementing, maintaining, and continually improving an information security management system (ISMS). Annex A of ISO 27001 provides a comprehensive set of 114 security controls organized into 14 domains. These controls are designed to address a wide range of information security risks.

Some key domains and controls include:

- **A.5 - Organizational Controls:** Focuses on establishing the organizational framework for information security, including roles, responsibilities, and policies.
- **A.6 - Human Resource Security Controls:** Addresses security aspects related to employees, from hiring to termination.



- **A.7 - Physical Security Controls:** Covers physical access controls and environmental security.
- **A.8 - Technological Controls:** Encompasses a wide range of technical security measures, such as access control, cryptography, and malware protection.
- **A.12 - Operational Security Controls:** Focuses on the day-to-day security operations, including change management, backup and recovery, and incident management.
- **A.14 - System Acquisition, Development and Maintenance:** Addresses security considerations throughout the system development lifecycle.



Example: Applying control A.12.3 (Backup) to mitigate ransomware risks involves regularly backing up critical data, storing backups in a secure location, and testing the restoration process to ensure data can be recovered in the event of an attack.

Framework Application

Mapping controls to real-world scenarios is crucial for effective cybersecurity. For example, in the context of ransomware mitigation:

- **NIST CSF's Recover:** Provides guidance on restoring systems and data from backups after a ransomware attack.
- **ISO 27001's A.8.2.1 (Data Classification):** Helps organizations identify and prioritize critical data for backup and recovery.



Key Objectives

The key objectives are to apply the NIST CSF and ISO 27001 to design and evaluate cybersecurity programs tailored to organizational needs. This involves:

- Understanding the core concepts and principles of each framework.
- Mapping controls to specific risks and vulnerabilities.
- Developing and implementing security policies and procedures.
- Monitoring and evaluating the effectiveness of security controls.
- Continuously improving the cybersecurity program based on feedback and lessons learned.

Mastering Cybersecurity Frameworks: A Practical Guide

This document provides a structured approach to learning and applying prominent cybersecurity frameworks, including NIST CSF, ISO 27001, and CIS Controls. It outlines a practical methodology for understanding these frameworks, mapping their controls, and applying them to real-world scenarios like ransomware attacks. By following these steps, individuals can gain a comprehensive understanding of cybersecurity best practices and enhance their ability to protect organizations from cyber threats.

Step 1: Deep Dive into NIST Cybersecurity Framework (CSF)

The National Institute of Standards and Technology (NIST) Cybersecurity Framework (CSF) is a widely adopted framework for improving cybersecurity risk management. To effectively learn and apply the NIST CSF, begin with a thorough review of the official guides available on the NIST website (NIST.gov).

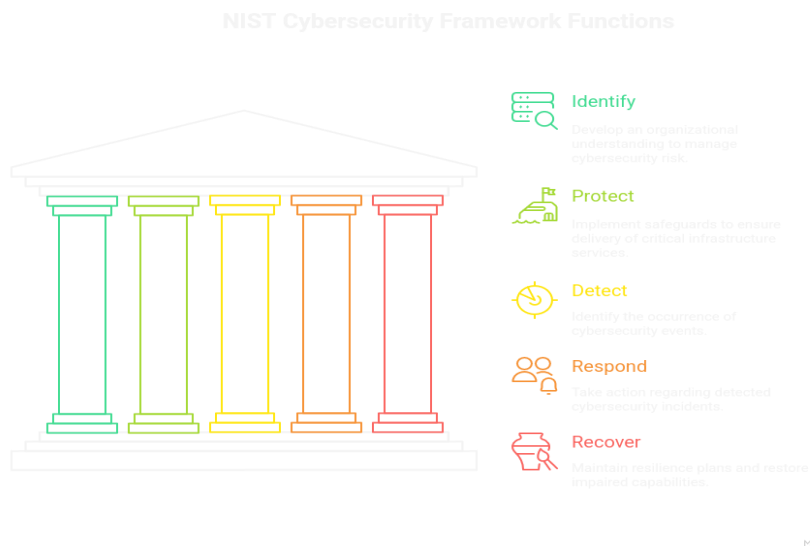
Understanding the Core Functions

The NIST CSF is structured around five core functions:

- **Identify (ID):** Develop an organizational understanding to manage cybersecurity risk to systems, assets, data, and capabilities.
- **Protect (PR):** Develop and implement appropriate safeguards to ensure delivery of critical infrastructure services.
- **Detect (DE):** Develop and implement appropriate activities to identify the occurrence of a cybersecurity event.
- **Respond (RS):** Develop and implement appropriate activities to take action regarding a detected cybersecurity incident.



- **Recover (RC):** Develop and implement appropriate activities to maintain plans for resilience and to restore any capabilities or services that were impaired due to a cybersecurity incident.



Studying Implementation Tiers

The NIST CSF defines four Implementation Tiers, which describe the degree to which an organization's cybersecurity risk management practices exhibit the characteristics defined in the Framework:

- **Tier 1: Partial:** Risk management is ad hoc and inconsistent. Awareness of cybersecurity risk is limited.
- **Tier 2: Risk-Informed:** Risk management is approved by management but may not be consistently applied. Awareness of cybersecurity risk is increasing.
- **Tier 3: Repeatable:** Risk management is formally approved and consistently applied. Awareness of cybersecurity risk is well-established.
- **Tier 4: Adaptive:** Risk management is continuously improved based on lessons learned and predictive indicators. Awareness of cybersecurity risk is pervasive throughout the organization.

Understanding these tiers is crucial for assessing an organization's current cybersecurity posture and identifying areas for improvement.



Step 2: Exploring ISO 27001

ISO 27001 is an international standard for information security management systems (ISMS). It provides a framework for establishing, implementing, maintaining, and continually improving an ISMS.

Utilizing Advisera Checklists

Advisera offers checklists and resources that can be invaluable for understanding and implementing ISO 27001. These checklists provide a structured approach to ensuring compliance with the standard's requirements.

Mapping Controls to a Ransomware Scenario

To gain a practical understanding of ISO 27001, map its controls to a ransomware scenario. For example:

- **Control A.5.1 Information security policies:** How would this control help prevent or mitigate a ransomware attack? (e.g., by establishing clear policies on acceptable use of devices and data handling).
- **Control A.8.3.1 Information backup:** How would this control help recover from a ransomware attack? (e.g., by ensuring that data can be restored from backups).
- **Control A.8.8.1 Management of technical vulnerabilities:** How would this control help prevent a ransomware attack? (e.g., by identifying and patching vulnerabilities that ransomware could exploit).

By mapping controls to a specific scenario, you can better understand their practical application and importance.

Step 3: Cross-Referencing CIS Controls with NIST CSF

The CIS Controls (formerly known as the SANS Top 20 Critical Security Controls) are a set of prioritized cybersecurity best practices. Cross-referencing the CIS Controls with the NIST CSF can help identify overlaps and synergies between the two frameworks.

Identifying Overlaps

For example, CIS Control 3 (Continuous Vulnerability Management) aligns with the NIST CSF Protect function (PR). Specifically, it relates to categories like PR.AC-4 (Access Control) and PR.PT-1 (Vulnerability Management).



By identifying these overlaps, you can leverage the strengths of both frameworks to create a more comprehensive cybersecurity program. The CIS Controls provide specific, actionable steps, while the NIST CSF provides a broader framework for managing cybersecurity risk.

Step 4: Analyzing the WannaCry Ransomware Case

The WannaCry ransomware attack was a global cyberattack that occurred in May 2017. Analyzing this case can provide valuable insights into how cybersecurity frameworks can be applied in real-world scenarios.

Utilizing CISA Reports

The Cybersecurity and Infrastructure Security Agency (CISA) has published reports on the WannaCry attack. These reports provide detailed information about the attack, its impact, and lessons learned.

Mapping NIST CSF Functions to Response Actions

Map the NIST CSF functions to the response actions taken during the WannaCry attack. For example:

- **Identify (ID):** How did organizations identify the risk of a ransomware attack like WannaCry? (e.g., through threat intelligence and vulnerability assessments).
- **Protect (PR):** What protective measures could have prevented the attack? (e.g., patching vulnerabilities, implementing strong access controls, and using anti-malware software).
- **Detect (DE):** How did organizations detect the WannaCry attack? (e.g., through intrusion detection systems and security information and event management (SIEM) systems).
- **Respond (RS):** What actions did organizations take to respond to the attack? (e.g., isolating infected systems, notifying stakeholders, and restoring data from backups).
- **Recover (RC):** How did organizations recover from the attack? (e.g., by restoring systems from backups, patching vulnerabilities, and implementing enhanced security measures).

By analyzing the WannaCry case through the lens of the NIST CSF, you can gain a deeper understanding of how the framework can be used to prevent, detect, respond to, and recover from cyberattacks.

Conclusion

Mastering cybersecurity frameworks requires a combination of theoretical knowledge and practical application. By following the steps outlined in this document, individuals can gain a comprehensive understanding of NIST CSF, ISO 27001, and CIS Controls, and enhance



their ability to protect organizations from cyber threats. Remember to continuously update your knowledge and skills as the cybersecurity landscape evolves.

Incident Response Fundamentals

This document provides a foundational understanding of incident response, covering the incident lifecycle and its key components. It outlines the essential phases of incident handling, from preparation to recovery, and emphasizes the importance of playbooks, SOC workflows, and incident prioritization in effectively managing security incidents.

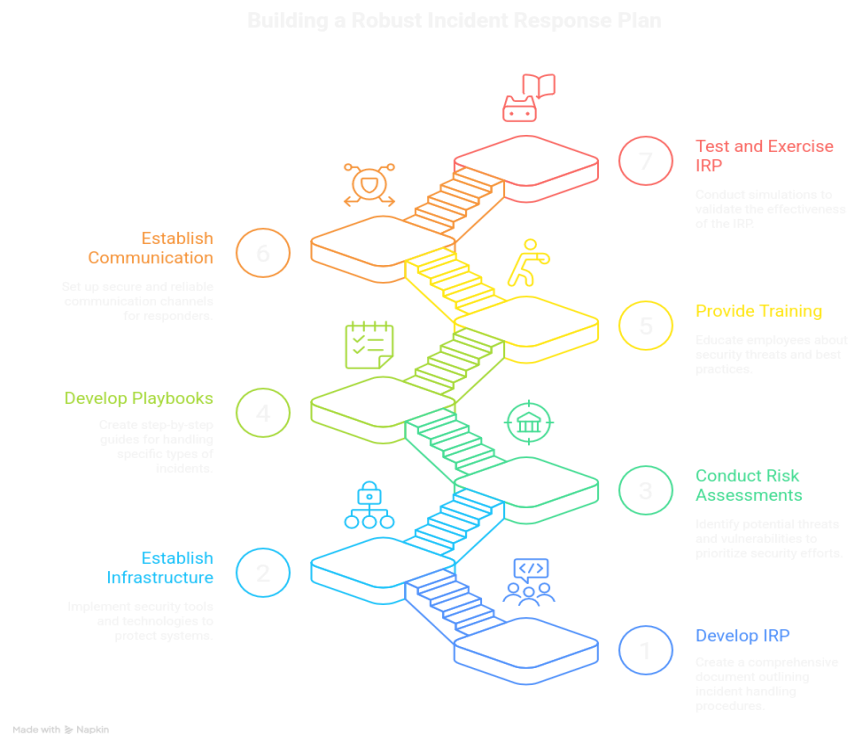
Incident Lifecycle

The incident lifecycle is a structured approach to handling security incidents, ensuring a systematic and effective response. It typically consists of the following phases:

1. Preparation

Preparation is the cornerstone of effective incident response. It involves establishing the necessary infrastructure, policies, procedures, and training to handle incidents efficiently. Key activities in this phase include:

- **Developing Incident Response Plan (IRP):** A comprehensive document outlining the organization's approach to incident handling, including roles, responsibilities, communication protocols, and escalation procedures.
- **Establishing Security Infrastructure:** Implementing security tools and technologies such as firewalls, intrusion detection/prevention systems (IDS/IPS), endpoint detection and response (EDR) solutions, and security information and event management (SIEM) systems.
- **Conducting Risk Assessments:** Identifying potential threats and vulnerabilities to prioritize security efforts and allocate resources effectively.
- **Developing Playbooks:** Creating step-by-step guides for handling specific types of incidents, providing clear instructions and checklists for responders.
- **Providing Security Awareness Training:** Educating employees about security threats, phishing scams, and best practices to prevent incidents.
- **Establishing Communication Channels:** Setting up secure and reliable communication channels for incident responders to collaborate and share information.
- **Regularly Testing and Exercising the IRP:** Conducting simulations and tabletop exercises to validate the effectiveness of the IRP and identify areas for improvement.



2. Detection

Detection involves identifying and recognizing potential security incidents. This phase relies on monitoring systems, security tools, and human observation to identify anomalous activity. Key activities in this phase include:

- **Monitoring Security Logs and Alerts:** Continuously monitoring security logs, alerts, and events from various sources to identify suspicious activity.
- **Analyzing Network Traffic:** Examining network traffic patterns for anomalies, such as unusual communication patterns, data exfiltration attempts, or malware infections.
- **Investigating User Reports:** Responding to user reports of suspicious activity, such as phishing emails, unusual system behavior, or unauthorized access attempts.
- **Utilizing Threat Intelligence:** Leveraging threat intelligence feeds to identify known indicators of compromise (IOCs) and proactively detect potential threats.
- **Implementing Anomaly Detection:** Using machine learning and behavioral analysis techniques to identify deviations from normal system behavior.
- **Validating Alerts:** Verifying the legitimacy of security alerts to avoid false positives and focus on genuine incidents.



3. Containment

Containment aims to limit the scope and impact of an incident by isolating affected systems and preventing further damage. Key activities in this phase include:

- **Isolating Affected Systems:** Disconnecting compromised systems from the network to prevent the spread of malware or unauthorized access.
- **Segmenting the Network:** Isolating affected network segments to contain the incident and prevent it from spreading to other parts of the network.
- **Disabling Compromised Accounts:** Disabling user accounts that have been compromised to prevent further unauthorized access.
- **Blocking Malicious Traffic:** Blocking malicious network traffic at the firewall or other security devices to prevent communication with command-and-control servers.
- **Collecting Evidence:** Preserving evidence related to the incident, such as logs, network traffic, and system images, for further analysis and investigation.
- **Communicating with Stakeholders:** Informing relevant stakeholders, such as management, legal counsel, and public relations, about the incident and containment efforts.

4. Eradication

Eradication focuses on removing the root cause of the incident and eliminating any remaining traces of the threat. Key activities in this phase include:

- **Identifying the Root Cause:** Determining the underlying cause of the incident, such as a software vulnerability, misconfiguration, or social engineering attack.
- **Removing Malware and Malicious Code:** Removing malware, viruses, and other malicious code from infected systems.
- **Patching Vulnerabilities:** Applying security patches and updates to address vulnerabilities that were exploited during the incident.
- **Reconfiguring Systems:** Correcting misconfigurations and security weaknesses that contributed to the incident.
- **Updating Security Controls:** Enhancing security controls, such as firewall rules, intrusion detection signatures, and access control policies, to prevent future incidents.
- **Verifying System Integrity:** Ensuring that systems are free from malware and vulnerabilities after eradication.

5. Recovery

Recovery involves restoring affected systems and services to normal operation. Key activities in this phase include:



- **Restoring Systems from Backups:** Restoring systems from backups to recover data and functionality.
- **Rebuilding Systems:** Rebuilding systems from scratch to ensure that they are free from malware and vulnerabilities.
- **Validating System Functionality:** Testing systems to ensure that they are functioning properly after recovery.
- **Monitoring Systems for Anomalous Activity:** Continuously monitoring systems for any signs of reinfection or further compromise.
- **Communicating with Users:** Informing users that systems have been restored and providing guidance on how to resume normal activities.

6. Lessons Learned

The lessons learned phase involves documenting the incident, analyzing the response efforts, and identifying areas for improvement. Key activities in this phase include:

- **Documenting the Incident:** Creating a detailed record of the incident, including the timeline of events, actions taken, and outcomes.
- **Analyzing the Response:** Evaluating the effectiveness of the incident response plan and identifying areas where it can be improved.
- **Identifying Root Causes:** Determining the underlying causes of the incident and developing strategies to prevent similar incidents in the future.
- **Updating Policies and Procedures:** Revising security policies, procedures, and training materials to reflect lessons learned from the incident.
- **Sharing Lessons Learned:** Sharing lessons learned with relevant stakeholders to improve overall security posture.

Key Components

Role of Playbooks

Playbooks are pre-defined, step-by-step guides for responding to specific types of security incidents. They provide clear instructions and checklists for incident responders, ensuring a consistent and effective response. Playbooks typically include:

- **Incident Description:** A brief overview of the type of incident the playbook addresses.
- **Detection Criteria:** Indicators and alerts that trigger the playbook.
- **Response Procedures:** Step-by-step instructions for containing, eradicating, and recovering from the incident.
- **Roles and Responsibilities:** Identification of the individuals or teams responsible for each step in the response process.
- **Communication Plan:** Guidelines for communicating with stakeholders during the incident.



- **Escalation Procedures:** Criteria for escalating the incident to higher levels of management or external resources.

SOC Workflows

Security Operations Center (SOC) workflows define the processes and procedures that SOC analysts follow to detect, investigate, and respond to security incidents. These workflows typically include:

- **Alert Triage:** Prioritizing and validating security alerts based on severity and potential impact.
- **Incident Investigation:** Gathering information about the incident, such as affected systems, users, and data.
- **Containment and Eradication:** Implementing measures to contain the incident and remove the threat.
- **Remediation:** Restoring affected systems and services to normal operation.
- **Documentation:** Recording all actions taken during the incident response process.
- **Escalation:** Escalating incidents to higher levels of management or specialized teams when necessary.

Incident Prioritization

Incident prioritization involves assessing the severity and potential impact of security incidents to determine the order in which they should be addressed. Factors to consider when prioritizing incidents include:

- **Impact:** The potential damage to the organization, such as data loss, financial loss, or reputational damage.
- **Severity:** The level of risk posed by the incident, based on factors such as the type of threat, the vulnerability exploited, and the sensitivity of the affected data.
- **Scope:** The number of systems and users affected by the incident.
- **Business Criticality:** The importance of the affected systems and services to the organization's operations.
- **Regulatory Compliance:** The potential for the incident to violate regulatory requirements.

By prioritizing incidents effectively, organizations can ensure that the most critical threats are addressed first, minimizing the potential for damage and disruption.

Learning Incident Response

This document outlines a practical approach to learning incident response, focusing on leveraging high-quality resources and hands-on experience. It recommends a combination of



studying SANS Institute incident response papers and utilizing the Let's Defend platform for simulated incident response scenarios. This blended approach provides a strong foundation in both theoretical knowledge and practical application, essential for aspiring incident responders.

Study SANS Incident Response Papers

The SANS Institute is a well-respected organization in the cybersecurity field, known for its comprehensive training courses and in-depth research. Their incident response papers are a valuable resource for anyone looking to learn about incident response.

Why SANS Papers?

- **Expertise:** SANS papers are written by industry experts with extensive experience in incident response.
- **Comprehensive Coverage:** They cover a wide range of topics, from the fundamentals of incident response to advanced techniques.
- **Practical Guidance:** SANS papers provide practical guidance and actionable advice that can be applied in real-world scenarios.
- **Up-to-Date Information:** SANS papers are regularly updated to reflect the latest threats and trends in cybersecurity.

How to Study SANS Papers Effectively

1. **Start with the Fundamentals:** Begin with introductory papers that cover the basic concepts of incident response, such as the incident response lifecycle, roles and responsibilities, and common incident types.
2. **Focus on Specific Areas:** Once you have a solid understanding of the fundamentals, you can focus on specific areas of interest, such as malware analysis, network forensics, or cloud security.
3. **Take Notes:** As you read, take detailed notes on key concepts, techniques, and tools. This will help you retain the information and refer back to it later.
4. **Create a Glossary:** Create a glossary of terms and acronyms that are commonly used in incident response. This will help you understand the language of incident response and communicate effectively with other professionals.
5. **Practice What You Learn:** Apply what you learn by working through practice scenarios or participating in capture-the-flag (CTF) competitions. This will help you solidify your understanding and develop your skills.
6. **Stay Up-to-Date:** Regularly check the SANS website for new papers and updates. The cybersecurity landscape is constantly evolving, so it's important to stay up-to-date on the latest threats and trends.



Examples of Relevant SANS Papers

- **The Incident Handler's Handbook:** A comprehensive guide to incident response, covering everything from planning and preparation to detection and containment.
- **SANS Institute Reading Room:** A collection of white papers on various cybersecurity topics, including incident response.
- **Network Security Monitoring:** Papers on network traffic analysis and intrusion detection.
- **Digital Forensics and Incident Response (DFIR):** Papers covering forensic investigation techniques and incident handling methodologies.

Use Let's Defend for Simulated Incident Response Scenarios

Let's Defend is a platform that provides simulated incident response scenarios. It allows you to practice your incident response skills in a realistic environment without the risk of damaging real systems.

Why Let's Defend?

- **Realistic Scenarios:** Let's Defend provides realistic scenarios that simulate real-world incidents.
- **Hands-On Experience:** It allows you to gain hands-on experience in incident response by working through simulated incidents.
- **Safe Environment:** You can practice your skills in a safe environment without the risk of damaging real systems.
- **Feedback and Guidance:** Let's Defend provides feedback and guidance to help you improve your skills.
- **Variety of Scenarios:** The platform offers a variety of scenarios, covering different incident types and skill levels.

How to Use Let's Defend Effectively

1. **Start with the Beginner Scenarios:** Begin with the beginner scenarios to familiarize yourself with the platform and the basics of incident response.
2. **Read the Scenario Briefing Carefully:** Before starting a scenario, read the briefing carefully to understand the context of the incident and your objectives.
3. **Follow the Incident Response Lifecycle:** Follow the incident response lifecycle as you work through the scenario. This will help you stay organized and ensure that you don't miss any important steps.
4. **Use the Available Tools:** Use the tools provided by Let's Defend to investigate the incident and gather evidence.



5. **Document Your Findings:** Document your findings as you work through the scenario. This will help you track your progress and learn from your mistakes.
6. **Review the Solution:** After completing a scenario, review the solution to see how you could have done things differently.
7. **Practice Regularly:** Practice regularly to improve your skills and stay sharp.

Key Features of Let's Defend

- **Alerting System:** Simulates real-world security alerts that trigger incident response activities.
- **Case Management:** Provides a platform to manage and track incident investigations.
- **SIEM Integration:** Integrates with a simulated Security Information and Event Management (SIEM) system for log analysis.
- **Endpoint Detection and Response (EDR):** Offers simulated EDR capabilities for endpoint investigation.
- **Threat Intelligence:** Incorporates threat intelligence feeds to enhance incident detection and analysis.

Combining SANS Papers and Let's Defend

The most effective way to learn incident response is to combine the theoretical knowledge gained from studying SANS papers with the practical experience gained from using Let's Defend.

1. **Study a SANS Paper on a Specific Topic:** For example, study a paper on malware analysis.
2. **Find a Relevant Scenario on Let's Defend:** Find a scenario on Let's Defend that involves malware analysis.
3. **Apply What You Learned:** Apply what you learned from the SANS paper to the scenario on Let's Defend.
4. **Repeat:** Repeat this process for different topics and scenarios.

By combining these two resources, you can develop a strong foundation in both the theory and practice of incident response. This will prepare you for a successful career in cybersecurity.

Conclusion

Learning incident response requires a dedicated and multifaceted approach. By combining the in-depth knowledge provided by SANS Institute incident response papers with the hands-on experience offered by Let's Defend, aspiring incident responders can develop the skills and expertise necessary to excel in this critical field. Remember to focus on the fundamentals, practice regularly, and stay up-to-date with the latest threats and trends. Good luck!



Risk Management: Advanced Concepts

This document delves into advanced risk management concepts, specifically focusing on the distinction between quantitative and qualitative risk assessment, and the importance of Business Impact Analysis (BIA). The primary objective is to equip readers with the knowledge and understanding necessary to quantify risks and effectively assess their potential impact on business operations.

Quantitative vs. Qualitative Risk Assessment

Risk assessment is a critical component of risk management, providing a structured approach to identify, analyze, and evaluate potential risks. There are two primary methods for risk assessment: quantitative and qualitative. Understanding the differences between these approaches is crucial for selecting the most appropriate method for a given situation.

Qualitative Risk Assessment

Qualitative risk assessment is a subjective approach that relies on expert judgment, experience, and historical data to assess the likelihood and impact of risks. It typically involves assigning descriptive categories, such as "high," "medium," or "low," to both the probability of a risk occurring and the severity of its potential consequences.

Characteristics of Qualitative Risk Assessment:

- **Subjective:** Relies on opinions and perceptions rather than numerical data.
- **Descriptive:** Uses qualitative terms to describe risk likelihood and impact.
- **Relatively Quick and Easy:** Can be performed with limited resources and data.
- **Focus on Prioritization:** Helps prioritize risks for further analysis and mitigation.

Advantages of Qualitative Risk Assessment:

- **Simplicity:** Easy to understand and implement, even with limited technical expertise.
- **Speed:** Can be performed quickly, allowing for rapid identification of critical risks.
- **Flexibility:** Adaptable to various situations and industries.
- **Communication:** Facilitates communication and collaboration among stakeholders.

Disadvantages of Qualitative Risk Assessment:

- **Subjectivity:** Prone to bias and inconsistencies due to reliance on personal judgment.
- **Lack of Precision:** Provides a general overview of risks but lacks precise numerical estimates.



- **Difficulty in Comparison:** Hard to compare risks objectively due to the use of qualitative scales.
- **Limited for Complex Decisions:** May not be sufficient for making complex decisions that require precise risk quantification.

Example of Qualitative Risk Assessment:

Consider the risk of a data breach. A qualitative assessment might categorize the likelihood of a data breach as "medium" based on the organization's current security measures and industry trends. The potential impact could be categorized as "high" due to the potential for financial losses, reputational damage, and legal liabilities. This assessment would then prioritize this risk for further analysis and mitigation efforts.

Quantitative Risk Assessment

Quantitative risk assessment is an objective approach that uses numerical data and statistical analysis to quantify the likelihood and impact of risks. It involves assigning numerical values to both the probability of a risk occurring and the potential financial or operational losses associated with it.

Characteristics of Quantitative Risk Assessment:

- **Objective:** Relies on numerical data and statistical analysis.
- **Precise:** Provides specific numerical estimates of risk likelihood and impact.
- **Data-Intensive:** Requires significant amounts of data and expertise.
- **Focus on Cost-Benefit Analysis:** Facilitates cost-benefit analysis of risk mitigation strategies.

Advantages of Quantitative Risk Assessment:

- **Objectivity:** Reduces bias and inconsistencies by relying on numerical data.
- **Precision:** Provides precise estimates of risk likelihood and impact.
- **Comparability:** Allows for objective comparison of risks based on numerical values.
- **Decision-Making:** Supports informed decision-making by providing quantitative data for cost-benefit analysis.

Disadvantages of Quantitative Risk Assessment:

- **Complexity:** Requires specialized knowledge and expertise in statistical analysis.
- **Data Requirements:** Demands significant amounts of accurate and reliable data.
- **Time-Consuming:** Can be time-consuming and resource-intensive to perform.
- **Uncertainty:** May be limited by uncertainty in data and assumptions.

Example of Quantitative Risk Assessment:



Consider the risk of a system failure. A quantitative assessment might estimate the probability of a system failure as 0.05 (5%) per year based on historical data and vendor information. The potential financial loss associated with a system failure could be estimated at \$100,000 based on lost revenue, recovery costs, and potential penalties. The Annualized Loss Expectancy (ALE) for this risk would be calculated as $0.05 * \$100,000 = \$5,000$. This quantitative assessment provides a clear numerical estimate of the potential financial impact of the risk.

Choosing Between Quantitative and Qualitative Risk Assessment

The choice between quantitative and qualitative risk assessment depends on several factors, including the availability of data, the complexity of the risks, the resources available, and the desired level of precision.

- **Use Qualitative Assessment When:**
 - Data is limited or unavailable.
 - Risks are complex and difficult to quantify.
 - Resources are constrained.
 - A general overview of risks is sufficient.
- **Use Quantitative Assessment When:**
 - Sufficient data is available.
 - Risks are well-defined and quantifiable.
 - Resources are available for data collection and analysis.
 - Precise estimates of risk likelihood and impact are required.

In many cases, a combination of both qualitative and quantitative risk assessment is used. Qualitative assessment can be used to identify and prioritize risks, while quantitative assessment can be used to further analyze and quantify the most critical risks.

Business Impact Analysis (BIA)

Business Impact Analysis (BIA) is a systematic process used to identify and evaluate the potential impact of disruptions to business operations. It helps organizations understand the critical functions, processes, and resources that are essential for their survival and success. The BIA also identifies the potential financial, operational, and reputational consequences of disruptions to these critical functions.

Key Objectives of BIA:

- Identify critical business functions and processes.
- Determine the impact of disruptions to these functions.
- Establish recovery time objectives (RTOs) and recovery point objectives (RPOs).
- Prioritize recovery efforts based on business impact.
- Inform the development of business continuity and disaster recovery plans.



Steps in Conducting a BIA:

1. **Identify Critical Business Functions:** Determine the core activities that are essential for the organization to achieve its objectives.
2. **Determine Interdependencies:** Identify the resources, systems, and processes that support each critical function.
3. **Estimate Downtime Impact:** Assess the potential financial, operational, and reputational consequences of disruptions to each critical function.
4. **Establish Recovery Time Objectives (RTOs):** Define the maximum acceptable downtime for each critical function.
5. **Establish Recovery Point Objectives (RPOs):** Determine the maximum acceptable data loss for each critical function.
6. **Document Findings:** Compile the results of the BIA into a comprehensive report.

Benefits of BIA:

- **Improved Business Continuity Planning:** Provides a foundation for developing effective business continuity and disaster recovery plans.
- **Enhanced Risk Management:** Helps identify and prioritize risks based on their potential impact on business operations.
- **Better Resource Allocation:** Enables organizations to allocate resources more effectively to protect critical functions.
- **Increased Resilience:** Enhances the organization's ability to withstand and recover from disruptions.
- **Compliance:** Helps organizations comply with regulatory requirements related to business continuity and disaster recovery.

Example of BIA:

Consider a manufacturing company. A BIA might identify the production line as a critical business function. The interdependencies for this function could include raw materials, equipment, personnel, and IT systems. The downtime impact could include lost production, delayed shipments, and customer dissatisfaction. The RTO for the production line might be 24 hours, and the RPO might be 4 hours. This information would then be used to develop a business continuity plan that ensures the production line can be restored within the specified RTO and RPO in the event of a disruption.

In conclusion, understanding the nuances of quantitative and qualitative risk assessment, coupled with the implementation of a thorough Business Impact Analysis, are crucial for effective risk management. These advanced concepts empower organizations to proactively identify, analyze, and mitigate potential risks, ensuring business continuity and resilience in the face of adversity.



Learning Risk Quantification with FAIR and Google Sheets

This document provides a practical guide to learning risk quantification using the Factor Analysis of Information Risk (FAIR) methodology and implementing calculations, specifically Annualized Loss Expectancy (ALE), within Google Sheets. It outlines the steps involved in understanding FAIR, applying its principles, and leveraging Google Sheets for efficient risk analysis and reporting.

Understanding FAIR

The FAIR methodology is a standard for information risk management that focuses on quantifying risk in financial terms. Unlike qualitative risk assessments that rely on subjective ratings, FAIR provides a structured approach to measuring and managing risk based on probabilities and financial impacts.

Key Concepts in FAIR

- **Risk:** The probable frequency and probable magnitude of future loss.
- **Loss Event Frequency (LEF):** The probable frequency, within a given time frame, that a threat agent will act against an asset. LEF is composed of Threat Event Frequency (TEF) and Vulnerability (Vuln).
 - **Threat Event Frequency (TEF):** The probable frequency that a threat agent will attempt to act against an asset.
 - **Vulnerability (Vuln):** The probability that a threat event will become a loss event.
- **Loss Magnitude (LM):** The probable magnitude of loss resulting from a loss event. LM is composed of Primary Loss Magnitude (PLM) and Secondary Loss Magnitude (SLM).
 - **Primary Loss Magnitude (PLM):** The loss resulting directly from the event.
 - **Secondary Loss Magnitude (SLM):** The loss resulting from the reaction to the event.

FAIR Institute Resources

The FAIR Institute is the primary source for comprehensive information and resources on the FAIR methodology. Their website (<https://www.fairinstitute.org/>) offers a wealth of materials, including:

- **FAIR Body of Knowledge:** A detailed explanation of the FAIR methodology, its principles, and its application.
- **FAIR Analysis Principles:** Guidance on conducting effective FAIR analyses.



- **Training and Certification:** Opportunities to become a certified FAIR analyst.
- **Community Forums:** A platform for connecting with other FAIR practitioners and sharing knowledge.

It is highly recommended to thoroughly review the FAIR Institute's resources to gain a solid understanding of the methodology before attempting to implement it.

Calculating Annualized Loss Expectancy (ALE)

Annualized Loss Expectancy (ALE) is a key metric in risk quantification, representing the expected monetary loss from a risk over a one-year period. It is calculated by multiplying the Single Loss Expectancy (SLE) by the Annualized Rate of Occurrence (ARO).

Formula

$$\text{ALE} = \text{SLE} * \text{ARO}$$

Where:

- **SLE (Single Loss Expectancy):** The expected monetary loss from a single occurrence of a risk event.
- **ARO (Annualized Rate of Occurrence):** The estimated number of times a risk event is expected to occur in a year.

Calculating SLE

$$\text{SLE} = \text{Asset Value} * \text{Exposure Factor}$$

Where:

- **Asset Value (AV):** The monetary value of the asset at risk.
- **Exposure Factor (EF):** The percentage of the asset value that would be lost if the risk event occurred.

Using Google Sheets for ALE Calculation

Google Sheets provides a convenient and accessible platform for performing ALE calculations. Here's a step-by-step guide:

1. **Create a New Google Sheet:** Open Google Sheets and create a new spreadsheet.
2. **Define Columns:** Create columns for the following variables:
 - a. Asset
 - b. Asset Value (AV)
 - c. Exposure Factor (EF)



- d. Single Loss Expectancy (SLE)
 - e. Annualized Rate of Occurrence (ARO)
 - f. Annualized Loss Expectancy (ALE)
3. **Populate Asset Information:** Enter the names of the assets you are assessing in the "Asset" column. For each asset, estimate and enter its monetary value in the "Asset Value" column.
4. **Estimate Exposure Factor:** For each asset, determine the potential percentage of loss if a specific risk event occurs. Enter this percentage as a decimal in the "Exposure Factor" column (e.g., 25% would be entered as 0.25).
5. **Calculate SLE:** In the "SLE" column, use the following formula to calculate the Single Loss Expectancy: $=B2*C2$ (assuming "Asset Value" is in column B and "Exposure Factor" is in column C, starting from row 2). Drag the formula down to apply it to all assets.
6. **Estimate ARO:** For each asset, estimate the number of times the risk event is likely to occur in a year. Enter this value in the "ARO" column. This estimation should be based on available data, historical incidents, and expert judgment.
7. **Calculate ALE:** In the "ALE" column, use the following formula to calculate the Annualized Loss Expectancy: $=D2*E2$ (assuming "SLE" is in column D and "ARO" is in column E, starting from row 2). Drag the formula down to apply it to all assets.
8. **Format as Currency:** Format the "Asset Value," "SLE," and "ALE" columns as currency to display the values in a monetary format.
9. **Analyze Results:** Review the calculated ALE values for each asset. This information can be used to prioritize risk mitigation efforts and allocate resources effectively.

Example

Risk Assessment Table

Asset	Asset Value	Exposure Factor	SLE	ARO	ALE
Database Server	\$100,000	0.5	\$50,000	0.1	\$5,000
Laptop	\$2,000	1	\$2,000	0.2	\$400
Website	\$50,000	0.2	\$10,000	0.05	\$500

Made with  Napkin



Advanced Techniques in Google Sheets

- **Data Validation:** Use data validation to restrict the values that can be entered in certain columns, such as "Exposure Factor" (e.g., between 0 and 1) and "ARO" (e.g., non-negative numbers).
- **Conditional Formatting:** Use conditional formatting to highlight assets with high ALE values, making it easier to identify the most critical risks.
- **Charts and Graphs:** Create charts and graphs to visualize the ALE data, such as bar charts showing the ALE for each asset or pie charts showing the distribution of ALE across different asset categories.
- **Scenario Analysis:** Create multiple scenarios with different values for "Exposure Factor" and "ARO" to assess the impact of different risk conditions on the ALE.

Tips for Effective Risk Quantification

- **Start Small:** Begin with a limited scope and focus on quantifying the risks associated with a few critical assets.
- **Gather Data:** Collect as much relevant data as possible to support your estimations of "Asset Value," "Exposure Factor," and "ARO."
- **Involve Stakeholders:** Engage with relevant stakeholders, such as asset owners, IT professionals, and business managers, to gather their input and validate your assumptions.
- **Document Assumptions:** Clearly document all assumptions made during the risk quantification process.
- **Regularly Review and Update:** Risk assessments should be regularly reviewed and updated to reflect changes in the threat landscape, asset values, and business operations.
- **Use Ranges:** Instead of single point estimates, consider using ranges for "Exposure Factor" and "ARO" to reflect the uncertainty inherent in risk quantification. This can be implemented in Google Sheets using formulas that calculate the minimum, maximum, and average ALE based on the ranges.
- **Focus on the Most Impactful Risks:** Prioritize your efforts on quantifying the risks that have the potential to cause the most significant financial losses.



Steps to Effective Risk Quantification



Made with Napkin

Conclusion

By combining the structured approach of the FAIR methodology with the accessibility and flexibility of Google Sheets, you can effectively learn and implement risk quantification techniques. This will enable you to make more informed decisions about risk management and allocate resources strategically to protect your organization's assets. Remember to continuously learn and adapt your approach as the threat landscape evolves.

Practical Application



1. Threat Hunting with Open-Source Tools

Requirements

We use the following infrastructure to demonstrate the detection of PowerShell abuse techniques in Windows endpoints with Wazuh:

- Wazuh 4.9.2 central components (Wazuh server, Wazuh indexer, Wazuh dashboard) installed on an kali server.
- A Windows 11 endpoint. This endpoint has a [Wazuh agent installed](#) and enrolled to the Wazuh server.

Configuration

To detect PowerShell abuse, we need to enable and collect PowerShell logs on the monitored Windows endpoint and create custom rules. This section describes how to configure the required components for detecting PowerShell abuse.

Windows endpoint

Perform the following steps to configure the Wazuh agent for log collection from PowerShell.

1. Open PowerShell as Administrator and run the following commands to enable PowerShell logging. This enables detailed logging in PowerShell as Windows does not collect detailed information about executed commands on PowerShell by default due to an increase in system resource usage and storage demands:

Run this in PowerShell with the administrator

```
function Enable-PSLogging { # Define registry paths for ScriptBlockLogging and
ModuleLogging $scriptBlockPath =
'HKLM:\Software\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging'
$moduleLoggingPath =
'HKLM:\Software\Policies\Microsoft\Windows\PowerShell\ModuleLogging'

# Enable Script Block Logging
if (-not (Test-Path $scriptBlockPath)) {
    $null = New-Item $scriptBlockPath -Force
}
Set-ItemProperty -Path $scriptBlockPath -Name EnableScriptBlockLogging -Value 1

# Enable Module Logging
if (-not (Test-Path $moduleLoggingPath)) {
```



```
$null = New-Item $moduleLoggingPath -Force
}
Set-ItemProperty -Path $moduleLoggingPath -Name EnableModuleLogging -Value 1

# Specify modules to log - set to all (*) for comprehensive logging
$moduleNames = @('*') # To specify individual modules, replace * with module names
in the array
New-ItemProperty -Path $moduleLoggingPath -Name ModuleNames -PropertyType
MultiString -Value $moduleNames -Force

Write-Output "Script Block Logging and Module Logging have been enabled."

}
```

Enable-PSLogging

- The expected output is as seen below:

Script Block Logging and Module Logging have been enabled.

2. Add the following configuration within the <ossec_config> block of the C:\Program Files (x86)\ossec-agent\ossec.conf file to forward PowerShell logs to the Wazuh server for analysis:

```
<localfile>
  <location>Microsoft-Windows-PowerShell/Operational</location>
  <log_format>eventchannel</log_format>
</localfile>
```

3. Restart the Wazuh agent to apply the configuration changes:

```
Restart-Service -Name wazuh
```

Wazuh server

Perform the following steps on the Wazuh server to create custom rules to monitor the PowerShell events of interest.

1. Add the following custom rules to the /var/ossec/etc/rules/local_rules.xml rule file:



```
<group name="windows,powershell,">
```

```
<rule id="100201" level="8">
```

```
<if_sid>60009</if_sid>
```

```
<field name="win.eventdata.payload" type="pcre2">(?)CommandInvocation</field>
```

```
<field name="win.system.message"
```

```
type="pcre2">(?)EncodedCommand|FromBase64String|EncodedArguments|-elb|-  
enco\b|-en\b</field>
```

```
<description>Encoded command executed via PowerShell.</description>
```

```
<mitre>
```

```
<id>T1059.001</id>
```

```
<id>T1562.001</id>
```

```
</mitre>
```

```
</rule>
```

```
<rule id="100202" level="4">
```

```
<if_sid>60009</if_sid>
```

```
<field name="win.system.message" type="pcre2">(?)blocked by your antivirus  
software</field>
```

```
<description>Windows Security blocked malicious command executed via  
PowerShell.</description>
```

```
<mitre>
```

```
<id>T1059.001</id>
```

```
</mitre>
```

```
</rule>
```

```
<rule id="100203" level="10">
```

```
<if_sid>60009</if_sid>
```

```
<field name="win.eventdata.payload" type="pcre2">(?)CommandInvocation</field>
```

```
<field name="win.system.message" type="pcre2">(?)Add-Persistence|Find-  
AVSignature|Get-GPPAutologon|Get-GPPPassword|Get-HttpStatus|Get-  
Keystrokes|Get-SecurityPackages|Get-TimedScreenshot|Get-VaultCredential|Get-  
VolumeShadowCopy|Install-SSP|Invoke-CredentialInjection|Invoke-  
DllInjection|Invoke-Mimikatz|Invoke-NinjaCopy|Invoke-Portscan|Invoke-  
ReflectivePEInjection|Invoke-ReverseDnsLookup|Invoke-Shellcode|Invoke-  
TokenManipulation|Invoke-WmiCommand|Mount-VolumeShadowCopy|New-  
ElevatedPersistenceOption|New-UserPersistenceOption|New-  
VolumeShadowCopy|Out-CompressedDll|Out-EncodedCommand|Out-  
EncryptedScript|Out-Minidump|PowerUp|PowerView|Remove-Comments|Remove-  
VolumeShadowCopy|Set-CriticalProcess|Set-MasterBootRecord</field>
```

```
<description>Risky CMDLet executed. Possible malicious activity  
detected.</description>
```

```
<mitre>
```

```
<id>T1059.001</id>
```

```
</mitre>
```



```
</rule>

<rule id="100204" level="8">
  <if_sid>91802</if_sid>
  <field name="win.eventdata.scriptBlockText"
type="pcre2">(?!mshta.*GetObject|mshta.*new ActiveXObject</field>
  <description>Mshta used to download a file. Possible malicious activity
detected.</description>
  <mitre>
    <id>T1059.001</id>
  </mitre>
</rule>

<rule id="100205" level="5">
  <if_sid>60009</if_sid>
  <field name="win.eventdata.contextInfo" type="pcre2">(?!ExecutionPolicy
bypass|exec bypass</field>
  <description>PowerShell execution policy set to bypass.</description>
  <mitre>
    <id>T1059.001</id>
  </mitre>
</rule>

<rule id="100206" level="5">
  <if_sid>60009</if_sid>
  <field name="win.eventdata.contextInfo" type="pcre2">(?!Invoke-
WebRequest|IWR.*-url|IWR.*-InFile</field>
  <description>Invoke Webrequest executed, possible download cradle
detected.</description>
  <mitre>
    <id>T1059.001</id>
  </mitre>
</rule>

</group>
```

Where:

- Rule ID 100201 detects when an encoded command is executed via PowerShell.
- Rule ID 100202 notifies when Windows Security blocks a user from running malicious commands.
- Rule ID 100203 detects when commands from tools with known malicious cmdlets are executed.
- Rule ID 100204 detects when Mshta is used to download and execute a file.



- Rule ID 100205 detects when a script has been executed with the execution policy set to bypass.
- Rule ID 100206 detects a possible download cradle where invoke-webrequest is used to download a file.

Restart the wazuh agent

systemctl restart wazuh-manager

Execution of malicious commands

Run this command to get output on this

curl

```
"https://raw.githubusercontent.com/BloodHoundAD/BloodHound/refs/heads/master/Collector/s/SharpHound.ps1" -o SharpHound.ps1  
powershell -ep bypass .\sharphound.ps1 --collectionmethod all
```

2. Malware Analysis Basics

Step 1: Copy calc.exe into REMnux

On your host machine:

1. Put calc.exe in a shared folder **or**
2. Use scp:

command

```
scp calc.exe remnux@<REMnux-IP>:/home/remnux/
```

Step 2: Run strings

Inside REMnux:

- **Command**

```
strings calc.exe > output.txt
```

- **To view the file**

```
less output.txt
```

Summirize Report

This analysis of calc.exe reveals several notable strings. "CalculatorStarted" and "CalculatorWinMain" indicate the application's initialization and main window processes. The embedded XML manifest shows Microsoft copyright and details like "dpiAware" for display



scaling. Key anti-debugging functions are present, including "TerminateProcess" and "UnhandledExceptionFilter," suggesting built-in protection mechanisms against analysis or tampering.

Anti-Virus Scan Results for OPSWAT Metadefender (12/26)

Last update: 2025-07-28 00:25:24 (UTC)

Vir.IT eXplorer	✓	K7	✗ Riskware (0040eff71)
AhnLab	✓	CMC	✗ Win32_Adware_RK_AA
RocketCyber	✓	Comodo	✗ ApplicUnwnt
ClamAV	✓	Huorong	✓
Bitdefender	✗ Gen:Variant.Application.RelevantKnowledge.119	Gridinsoft	✗ Adware.Win32.PremierOpinion.ddlc
Avira	✗ ADWARE/Relevant.qwxtc	Filseclab	✓
Zillya!	✗ Adware.RK.Win32.2661	Sophos	✓
VirusBlokAda	✗ BScope.Adware.Relevant	McAfee	✓
NETGATE	✓	TACHYON	✓
Varist	✗ W32/ABRisk.PARL-4561	Antiy	✓
Lionic	✓	Webroot SMD	✗ Malware_49.3
Emsisoft	✓	NANOAV	✗ Riskware.Win32.Relevant.jxojww
ESET	✗ a variant of Win32/Adware.RK_AA application	Cylance	✓

Close

Here is a short comparison table based on the analysis.

Feature	Static Analysis ("calc.exe" Summary)	AV Scan Results (Sandbox)	Conclusion
Stated Identity	Appears as Windows Calculator	Scanned as a generic file	The file is masquerading as a trusted program.
Key Findings	Legitimate calculator strings mixed with anti-debugging functions.	12/26 engines detect it as Adware (RelevantKnowledge) .	The suspicious functions align with the malicious AV verdict.
Overall Verdict	Potentially legitimate file with added suspicious code.	Clearly identified as a specific threat.	The file is a trojanized application containing adware.



3. Build a Vulnerability Management Pipeline

Tools: OpenVAS

Scan image

The screenshot shows the OpenVAS web interface. The left sidebar contains navigation links: Dashboards, Scans, Tasks, Reports, Results, Vulnerabilities, Notes, Overrides, Assets, Resilience, Security Information, Configuration, Administration, and Help. The main content area displays a vulnerability report for 'UnrealIRCd Authentication Spoofing Vulnerability'. The report includes a summary, detection result, product detection result, insight, detection method, affected software/OS, impact, solution, and references. The severity is 7.5 (High). The host is 172.20.10.2. The location is 6697/tcp. The EPSS score is N/A and the Percentile is N/A. The report was created on Thu, Nov 20, 2025 3:17 PM Coordinated Universal Time.

here are the 3 main vulnerabilities prioritized by severity:

Vulnerability	CVSS Score	Description
UnrealIRCd Authentication Spoofing	7.5	Allows attackers to spoof certificate fingerprints and log in as other users
FTP Weak Credentials	7.5	Multiple default credentials (msfadmin:msfadmin, postgres:postgres, etc.) allow unauthorized access
RSH Unencrypted Cleartext Login	5.0	Unencrypted remote shell service allows unauthorized access and communication interception

Prioritization Rationale:

- **UnrealIRCd Vulnerability (High):** Critical authentication bypass that could allow impersonation of any user



- **FTP Weak Credentials (High):** Multiple working default credentials provide immediate unauthorized access
- **RSH Service (Medium):** Unencrypted service poses significant risk but requires network access to exploit

4. Incident Response Simulation

I tried many times but some how I cannot get download and work on this task, so I am not submitting this task.

5. Network Defense with Open-Source Tools

Tools: Suricata

Installation command

```
sudo apt update && sudo apt install -y suricata suricata-update && sudo suricata-update && sudo systemctl enable --now suricata
```

Create rules

Cd /etc/suricata/rules

Create file

Nano local.rules

```
#####
```

SURICATA TEST RULE PACK (SAFE)

```
#####
```

1. ICMP Ping Test

```
alert icmp any any -> any any (msg:"TEST - ICMP ping detected"; sid:1000001; rev:1;)
```



2. HTTP Keyword Match

```
alert http any any -> any any (msg:"TEST - HTTP keyword match"; content:"test123";  
http_uri; sid:1000002; rev:1;)
```

3. DNS Query Test

```
alert dns any any -> any any (msg:"TEST - DNS query for example.com"; dns.query;  
content:"example.com"; sid:1000003; rev:1;)
```

4. TLS SNI Match

```
alert tls any any -> any any (msg:"TEST - TLS SNI test.local"; tls.sni; content:"test.local";  
sid:1000004; rev:1;)
```

5. TCP Port Connection Test (4444)

```
alert tcp any any -> any 4444 (msg:"TEST - Connection to TCP port 4444"; sid:1000005;  
rev:1;)
```

6. Base64 Pattern Match (dGVzdA==)

```
alert tcp any any -> any any (msg:"TEST - base64 pattern match"; content:"dGVzdA==";  
sid:1000006; rev:1;)
```

7. HTTP User-Agent Test

```
alert http any any -> any any (msg:"TEST - HTTP User-Agent match";  
content:"SuricataTest"; http_user_agent; sid:1000007; rev:1;)
```

8. Fake Malware Keyword Detection

```
alert tcp any any -> any any (msg:"TEST - Fake malware string detected";  
content:"malware_test_string"; sid:1000008; rev:1;)
```

9. Powershell Reverse Shell Keyword

```
alert http any any -> any any (msg:"TEST - Powershell reverse shell keyword";  
content:"powershell -nop -w hidden"; sid:1000009; rev:1;)
```



10. Suspicious Curl Command

alert http any any -> any any (msg:"TEST - Suspicious curl UA"; content:"curltestscanner"; http_user_agent; sid:1000010; rev:1;)

Start Command

suricata -c /etc/suricata/suricata.yaml -i wlan0

Check logs

Cat /var/log/suricata/fast.log

```

root@kali: ~
cat /var/log/suricata/fast.log
11/21/2025-14:09:50.278245 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:10:53.898999 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:11:03.838902 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:12:17.910826 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:13:30.035646 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:13:32.493116 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:14:40.213686 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:15:58.897022 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:16:00.125473 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:17:14.096840 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:18:27.963219 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67
11/21/2025-14:19:01.465103 [**] [1:2027397:1] ET INFO Spotify P2P Client [**] [Classification: Not Suspicious Traffic] [Priority: 3] {UDP} 192.168.0.120:57621 -> 192.168.0.255:57621
11/21/2025-14:19:42.036009 [**] [1:2022973:1] ET INFO Possible Kali Linux hostname in DHCP Request Packet [**] [Classification: Potential Corporate Privacy Violation] [Priority: 1] {UDP} 0.0.0.0:68 -> 255.255.255.255:67

```

For more information visit this link:

<https://wazuh.com/blog/responding-to-network-attacks-with-suricata-and-wazuh-xdr/>

Alert	Tactic	Technique	Notes
Possible Kali Linux hostname in DHCP Request Packet	Discovery	T1016 - System Network Configuration Discovery	The alert indicates a system with a known attacker-associated hostname (Kali Linux) is initiating network communication (DHCP Request). Adversaries use this to gather network configuration details like IP/MAC addresses to plan follow-on actions.



Possible Spotify P2P Client	Command and Control	T1573 - Encrypted Channel	Spotify P2P is non-standard traffic that, while legitimate for the application, can be used by an adversary for C2 communication, especially if it utilizes encryption to mask activity. P2P traffic can also be related to T1071 (Application Layer Protocol).
-----------------------------	----------------------------	----------------------------------	--

6. Risk Assessment Practice

Tools: Google Sheets

I created a Google Sheet for this.

7. Create an Incident Response Report

Tools: google docs

I have attached report in file

8. Capstone Project: Full Incident Response Cycle

Tools:

Wazuh for detection

Windows as victim

Kali linux as attacker

Incident Alert Summary

Timestamp	Source IP	Alert Description	MITRE Technique
2025.01.01 (Inferred)	172.20.10.4	Network Logon (Type 3) using NTLM to host WINDOWS19PROOO/WINDOWS10PROOO	T1110 - Brute Force
2025.01.01 (Inferred)	172.20.10.4	Special Privileges Assigned (Event ID 4672) to Administrator on WINDOWS10PROOO	T1078 - Valid Accounts
2025.01.01 (Inferred)	172.20.10.4	Account Logoff (Event ID 4634) for user admin on WINDOWS10PROOO	T1078 - Valid Accounts

**Containment:**

The attacker's IP address 172.20.10.4 has been blocked using CrowdSec. A subsequent ping test to this IP has confirmed that the host is now unreachable, effectively containing the immediate threat.

Incident Report

Findings:

Security monitoring detected a series of suspicious activities originating from the IP address 172.20.10.4. The initial alert flagged a Network Logon (Logon Type 3) using the NTLM authentication protocol to a host named WINDOWS19PROOO. This was immediately followed by a high-severity event (ID 4672) on WINDOWS10PROOO, indicating that special privileges were assigned to a new logon by the Administrator account. The assigned privileges, including SeDebugPrivilege and SeBackupPrivilege, are highly powerful and often exploited for privilege escalation and persistence. Subsequently, an account logoff event (ID 4634) was recorded for a user named admin. The sequence of a remote logon, immediate assignment of critical privileges, and a logoff suggests a successful credential-based compromise and lateral movement attempt within the network.

Actions Taken:

The source IP 172.20.10.4 was identified as the threat origin and was promptly blocked at the network level via CrowdSec. Connectivity tests confirm the block is active. All related logs have been archived for further forensic analysis.

Recommendations:

1. Investigate the Administrator and admin accounts for any signs of compromise or misuse.
2. Enforce a policy mandating strong, unique passwords and consider implementing multi-factor authentication (MFA) to mitigate credential-based attacks.
3. Strengthen NTLM usage policies; where possible, disable NTLM in favor of the more secure Kerberos protocol.
4. Conduct a thorough review of all systems for indicators of compromise (IOCs) and ensure all endpoints are updated with the latest security patches.